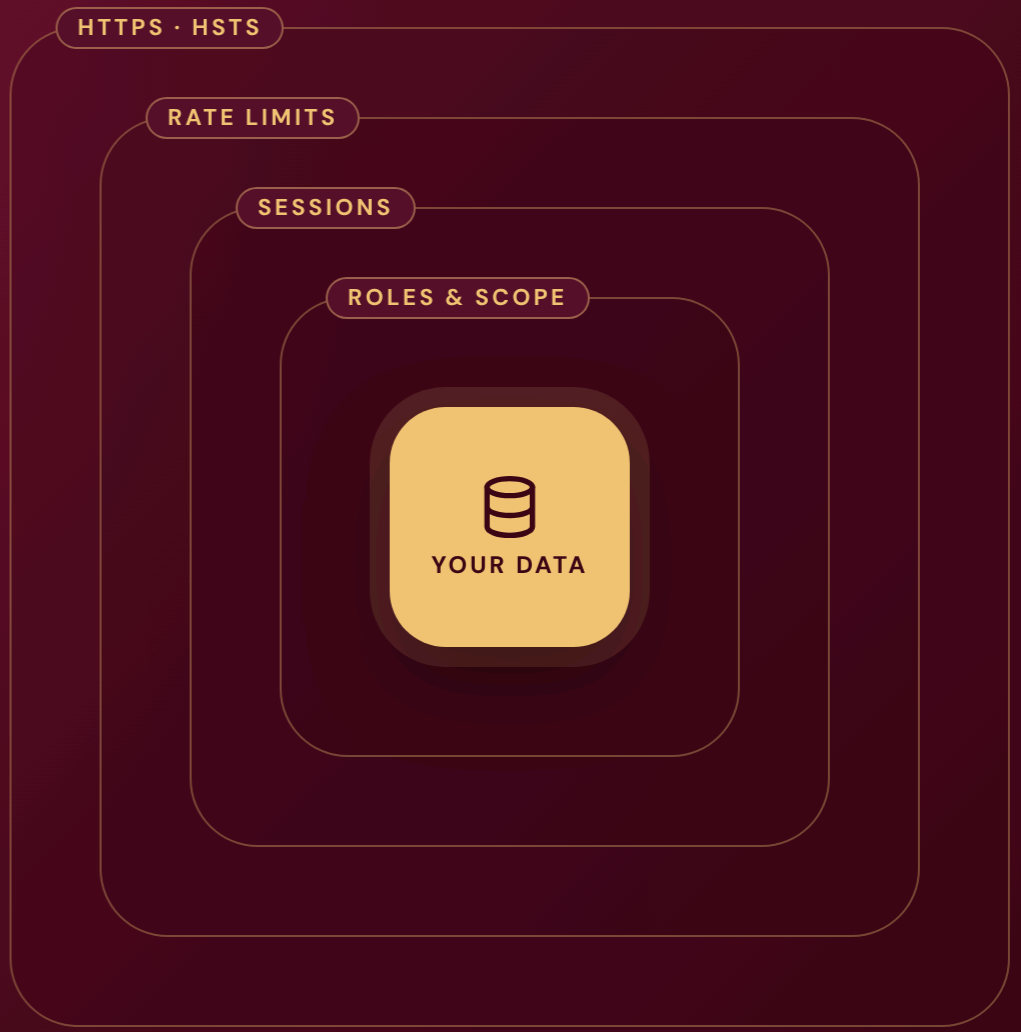
ATLAS Education platform by Lancaster

SECURITY & TECHNOLOGY · NOVEMBER 2026

Security, in *layers.*

Every request to ATLAS passes eight checks before it reaches a school's records. Here is each layer, and the technology underneath.

Built and tested by the Lancaster team



THE PATH OF EVERY REQUEST

Eight checks before *anything* reaches your data.

A request that fails a check is turned away with a clear answer, and the server keeps running for everyone else. Nothing below is an add-on: each check is part of ATLAS itself, or of the server it runs on.

1	**HTTPS only** CADDY	Every connection is encrypted, and browsers are told never to use plain HTTP for a year (HSTS).	× Eavesdropping on shared Wi-Fi
2	**Address check** SERVER	Requests must be addressed to the school's own ATLAS address. Malformed ones get a plain "400" and go no further.	× Host-header tricks, crash attempts
3	**Rate limits** SERVER	Each person and each network address has a budget per minute; past it, the answer is "429, try again in a moment".	× Floods, password-guessing scripts
4	**Same-site only** SERVER & BROWSER	Changes are accepted only as JSON from ATLAS's own pages; the sign-in cookie is never sent with another site's request.	× Cross-site request forgery
5	**Session** SIGN-IN	A 256-bit random token in a cookie that page scripts cannot read. Idle sessions end on their own (after 8 hours by default).	× Guessed or borrowed sessions
6	**Role & permission** EVERY ROUTE	Each of ATLAS's 400 API routes states who may call it, and is checked against the account's role and permissions.	× Doing what your role cannot
7	**Scope** CAMPUS, CLASS, FAMILY	Staff see their own campus, teachers their own sections, students their own work, parents only their linked children.	× Seeing other people's records
8	**Business rules** SEPARATION OF DUTIES	Whoever prepares or certifies a voucher cannot approve it; officers cannot change their own pay, leave or attendance.	× One person controlling a transaction

Your school's records

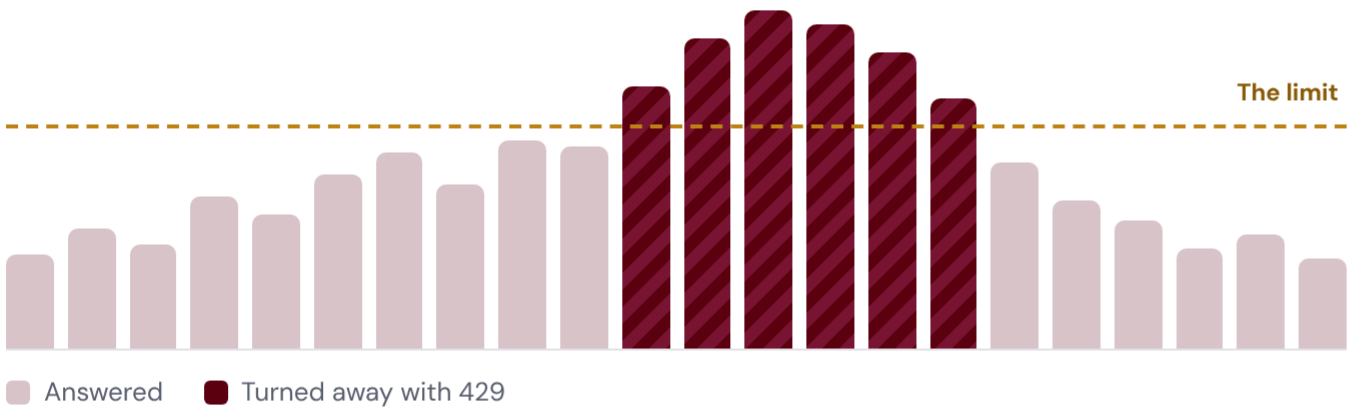
Changed only by a request that passed all eight, with an audit trail of who changed what, and when.

LAYER 3 · THE RATE LIMITER

A limit on every *door.*

ATLAS counts requests in a sliding window, per person when signed in and per network address when not. Sign-in, applications and lookups each have a tighter limit of their own. It is built into the server: no extra service to run.

REQUESTS FROM ONE SCRIPT, SECOND BY SECOND — ILLUSTRATION



WHAT A SCRIPT GETS PAST THE LIMIT

```
HTTP/1.1 429 Too Many Requests
Retry-After: 12
```

People never see this in normal use: the limits sit well above what a busy teacher or registrar does.

300 a minute

Each signed-in person

Any API request. Administrators can set 60 to 3,000.

4× per address

Visitors not signed in

Higher, because a whole school may share one internet address.

60 a minute

Sign-in attempts

Per network address. Each one is a deliberately slow password check.

30 in 15 minutes

Wrong passwords, any usernames

Per network address: stops guessing one password across many accounts.

5 wrong tries

One username, one address

Locks that username for that address only, so a stranger cannot lock out the administrator.

10 an hour

Applications for admission

Per network address, on the public form. Lookups and calendar feeds: 60 a minute.

LAYER 5 · PASSWORDS AND SIGN-IN

Passwords that are no use to *a thief.*

ATLAS never stores a password. It keeps a one-way scrypt hash, and then locks that hash with AES-256-GCM under a key kept apart from the data.

TYPED

The password

••••••••••

STEP 1 · SCRYPT

Hashed one way

Salted and deliberately slow, so guessing it costs time; it cannot be turned back into the password.

STEP 2 · AES-256-GCM

Then encrypted

With a key the server keeps outside the data: in its settings or a file only ATLAS can read.

STORED

`enc1$k1$Qm9v…$c2Vh…`

All the data file ever holds.

A copy of the data on its own holds no hashes to crack: the key is not in it. Keys can be changed without anyone resetting a password.

ATLAS SIGN-IN

- Session cookies are HttpOnly, SameSite=Strict and Secure
- The same answer, in the same time, whether or not a username exists
- A password change ends every other session of that account
- Administrators set the length and mix of passwords, and the lock-out

OPTIONAL · KEYCLOAK SINGLE SIGN-ON

- OpenID Connect with PKCE, state and nonce
- The server checks each token's signature, issuer, audience and expiry
- Accounts link only by a verified email; the client secret stays on the server
- The school's own Keycloak rules apply, including two-step sign-in where it is on

LAYERS 6 TO 8 · ACCESS AND DUTIES

The right people, *and only them.*

Access in ATLAS follows the school's own structure: roles, campuses, classes and families. Money and pay follow government rules on separation of duties.

Roles and permissions

Each role has its own permissions. Only an administrator can change what a role may do.

Campus, class and family scope

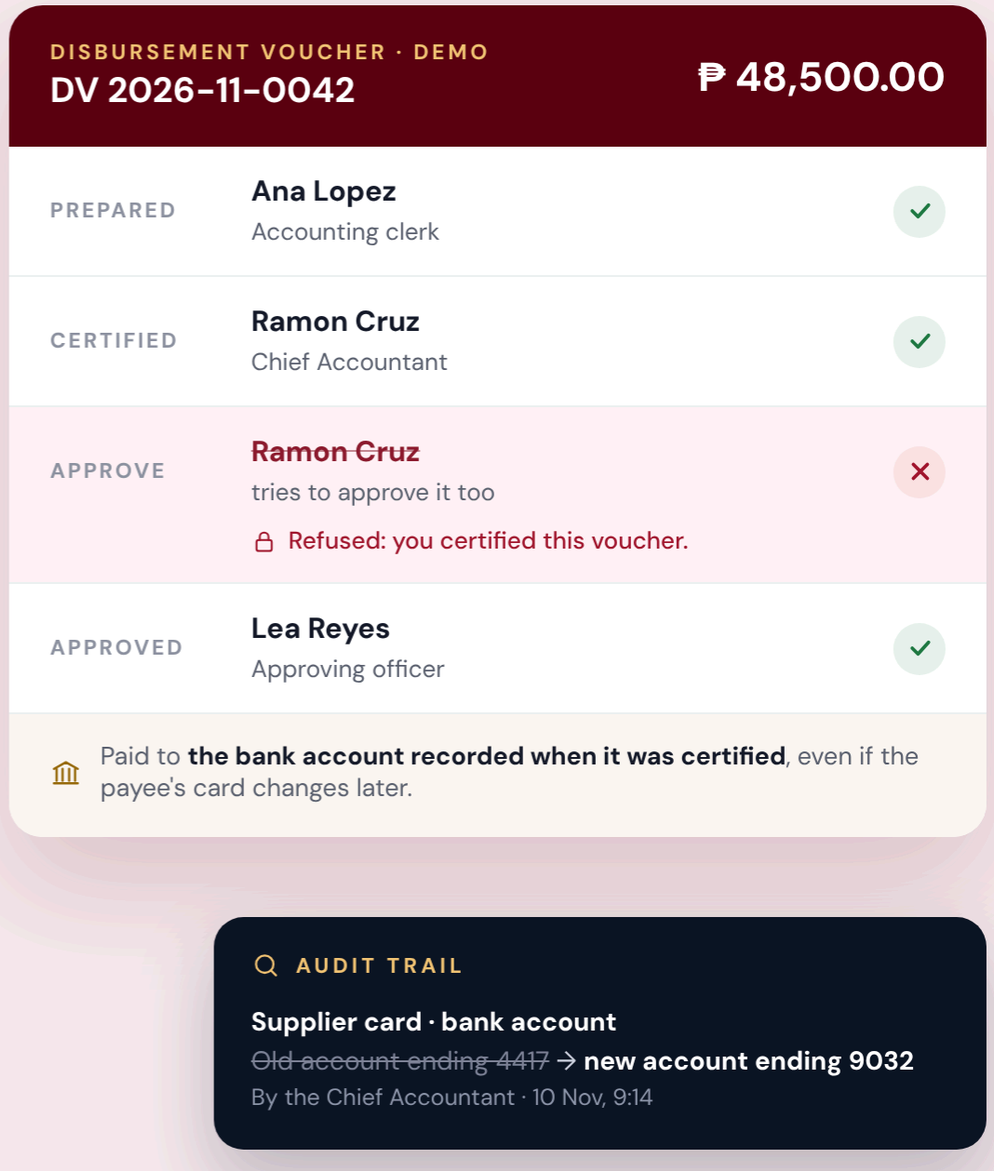
Checked on every record, in Learn, Academic, People and Finance alike.

Separation of duties

Whoever prepares or certifies a voucher cannot approve it. No one approves their own requisition or changes their own pay, leave or attendance.

Audit trails

Finance changes keep the old and the new value; every settings change can be traced and undone.



IN THE BROWSER

Safe on the screen, *too.*

Every page ATLAS sends carries headers that tell the browser what it may run, load and frame, and everything people type is escaped before it is shown.

RESPONSE HEADERS · EVERY PAGE

```
Content-Security-Policy: default-src 'self';
  script-src 'self' 'sha256-…'; frame-ancestors 'self' …
Strict-Transport-Security: max-age=31536000
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Referrer-Policy: same-origin
Permissions-Policy: camera=(), microphone=(), payment=() …
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Cache-Control: no-store
Set-Cookie: … HttpOnly; SameSite=Strict; Secure
```

Only ATLAS's own scripts run

A strict Content-Security-Policy: no outside scripts, no inline code but one fingerprinted snippet.

Everything typed is escaped

Names, titles and comments are shown as text, never run as code.

Safe exports

Spreadsheet formulas are neutralised in CSV files; calendar feeds are escaped too.

Uploads kept in a sandbox

Stored under random names; only PDFs, images, audio and video open in the browser, the rest download.

THE SERVER · AMAZON WEB SERVICES

A locked-down *server.*

ATLAS runs on one Amazon EC2 server set up from a single CloudFormation template, so every school's server is set up the same way.

Network
SECURITY GROUP

- Only ports 80 and 443 are open
- No SSH: administrators connect through AWS Session Manager

Disk & data
ENCRYPTED EBS

- The whole disk is encrypted
- The data folder and password key are closed to other accounts

Instance
UBUNTU 24.04 LTS

- Automatic security updates, Node.js included
- Instance metadata requires IMDSv2 tokens

Service
SYSTEMD SANDBOX

- Runs as its own account, never as root
- The rest of the system is read-only to it; it writes only to its data folder

Updates
TESTED BEFORE INSTALLED

- Every test runs first, as an unprivileged account with no network
- Installed only if all pass; otherwise the old version stays

Backups
TWO KINDS

- A copy of the data every night, kept 30 days
- A snapshot of the whole disk every day, the last 7 kept

Caddy: automatic HTTPS certificates

Secrets in the server's settings, never in the code

Or one computer on the school's own network

THE FRAMEWORK AND THE BACKEND

Built on the *standard library.*

ATLAS uses no web framework and no outside packages: every line is Lancaster's own or part of Node.js itself. Fewer moving parts means fewer places for a weakness to hide, and nothing to patch but Node.

BROWSER	**Plain JavaScript** ES modules, served as written	**No build step** No framework, no bundler	**HTML & CSS** Light and dark, desktop and phone	**7 web apps** Home, Learn, Admin, Academic, People, Finance, Help
EDGE	**Caddy** HTTPS, HSTS, reverse proxy	**Keycloak** Optional single sign-on	**OpenID Connect** With PKCE, state and nonce	**TLS certificates** Issued and renewed by Caddy
SERVER	**Node.js 22 LTS** One program, one process	**node:http** The web server and JSON API	**node:crypto** scrypt, AES-256-GCM, tokens	**node:fs** Atomic saves, never half-done	**node:test** The automated tests
DATA	**JSON data store** data/db.json, one list per table	**File store** Uploads under random names	**Ready for PostgreSQL** When one server is not enough	**Backups** Nightly copy, kept 30 days
PLATFORM	**Amazon EC2** Set up by CloudFormation	**Ubuntu 24.04 LTS** With systemd	**Encrypted EBS** Daily snapshots	**Playwright** Screenshots and browser checks only

0 outside packages to install or patch	**~30k** lines of code, all of it Lancaster's own	**400** API routes, each with its own access rule	**125** automated tests before every update	**1** server for every system and campus

Why zero packages matters: most web apps pull in hundreds of other people's packages, and each is a door someone else holds the key to.

CHECKED, THEN CHECKED AGAIN

Every fix stays *fixed.*

ATLAS's security is tested in code, not just on paper. Each issue found in a review gets an automated test, and every update must pass them all before it is installed.

125

Automated tests

25 of them security tests: malformed requests, limits, sessions, access by role, escaping.

2

In-house security reviews

November 2026: code review and live probes of every app, findings fixed and retested.

9,400

Fields tried with a script

Across about 660 screens, opened as administrator, registrar, teacher, student and parent.

Security is never finished: reviews continue, and every update runs the full test suite before it is installed.

FOR YOUR IT OFFICE

Secure by design. *Simple to run.*

Want the details? Ask Lancaster for a walkthrough of ATLAS's security set-up with your IT office, or read the Administrator guide under Help.

